

CO 4
Assessment
Tool - 03

Case study

Name : A. saijoshitha

Reg no : 192424220

Course code : IIA1408

Course Name: Ethical Hacking.

Q1. E-commerce web Application security Assessment.

Introduction:

The given case involves a mid-sized e-commerce company whose web application is hosted on an Apache server running on linux. Customers have reported unauthorized transactions and abnormal account activities. The investigation also identified suspicious HTTP requests, attempts to access hidden directories, malicious scripts in input fields, outdated software components, and the absence of a web application firewall (WAF). Therefore, a complete security assessment is required to identify vulnerabilities and protect the application.

Reconnaissance:

Reconnaissance is the first stage of security testing. Information about the server, ports, services and technologies is collected. Nmap can identify open ports and running services. Whatweb can identify web technologies and server information. Gobuster can identify accessible directories in an authorized environment. This information helps to identify the attack surface.

Vulnerability scanning

Vulnerability scanning identifies weakness in the web application. Nikto can check web-server

vulnerabilities and misconfiguration. Burp suite can analyze HTTP requests and responses. OWASP ZAP can identify common web application weakness. The tester checks authentication, input validation, and session management

Vulnerability Analysis:

The application should be checked for SQL injection and XSS. Hidden directories may expose confidential files and information. outdated Apache software may contain known vulnerabilities. weak authentication may allow unauthorized account access. All identified vulnerabilities should be documented and rated

Impact:

confidentiality may be affected if customer information is exposed. integrity may be affected if transactions are modified. Availability may be affected if the website is disrupted. unauthorized transactions can cause financial losses. customer trust and company reputation may also be damaged.

Conclusion:

Security testing helps identify weakness before attackers exploit them. server hardening reduces the attack surface. secure coding prevents common web application attacks. This improves the application.

Q2. SQL injection and XSS

Introduction:

The financial application allows users to access account information and transactions. Testing identified SQL injection and XSS vulnerabilities. These weaknesses are caused by improper input validation. Attackers may exploit these weaknesses to access sensitive information. Therefore, immediate security improvements are required.

SQL Injection:

SQL injection occurs when unsafe input reaches database queries. Login and search fields can be vulnerable.

Burp Suite and SQLmap can assist authorized testing. Testing must not access real financial data.

XSS:

XSS occurs when untrusted input is displayed without proper encoding. It can affect profiles, searches, comments, and messages. Burp Suite and OWASP ZAP can help identify XSS. Testing should use harmless data in a controlled environment.

Testing methodology:

Identify input fields and application parameters. Intercept requests using Burp Suite. Check input validation and application response. Document vulnerabilities and recommended solutions.

Impact:

confidential information may be exposed. Account or transaction data may be modified. Application availability may be affected. financial losses and reputation damage may occur.

Counter measures:

use parameterized queries and prepared statements
Implement server-side input validation and output encoding. use secure sessions and content security Policy. Perform regular security testing.

Conclusion;

SQL Injection and XSS are serious web vulnerabilities
Secure coding can prevent these attacks. proper validation protects application and database resources
Regular testing improves financial application security

Q3. WPA2-PSK and Evil Twin Attack

Introduction:

The organization provides WPA2-PSK Wi-Fi to employees. Employees reported unusual login prompts and slow connectivity. A possible evil twin attack was identified. Employee credentials and communication may be at risk.

Evil Twin Attack:

An Evil Twin is a fake wireless access point. It imitates the legitimate Wi-Fi network. users may accidentally connect to the fake network.

Credentials and sensitive communication may be exposed.

Attack Analysis

wireless testing must be performed with authorization. Aircrack-ng can be used for wireless security assessment. Wireshark can analyze network traffic. Kismet can help identify wireless and rogue devices.

Detection

Monitor SSIDs and BSSID/MAC addresses. Duplicate SSIDs may indicate a rogue access point. Unknown devices and unusual signals should be investigated. Suspicious authentication requests should be monitored.

Weakness

Shared WPA2-PSK passwords can increase security risks. Weak passwords are easier to compromise. Lack of enterprise authentication creates additional risk. Poor wireless monitoring may allow rogue devices.

Counter Measures

Use WPA2-Enterprise or WPA3-Enterprise. Implement 802.1X authentication. Monitor and remove rogue access points. Train employees to identify suspicious Wi-Fi networks.

Conclusion

Evil Twin attacks threaten wireless credentials and communication. Enterprise authentication provides stronger protection. Wireless monitoring helps detect

rogue access points. Employee awareness further improves wireless security.

Q4. Employee Management System

Introduction:

The organization uses a web-based employee management system. The system has authentication and input validation weakness. Attackers may attempt to access employee information. A complete authorized penetration is required.

Reconnaissance

Identify hosts, ports, services, and web technologies. Nmap can perform port and service discovery. Whatweb can identify web technologies only. Authorized systems should be tested.

Scanning:

Scanning identifies possible security vulnerabilities. Nmap identifies open ports and services. Nikto checks common web-server weaknesses. OpenVAS can assist with vulnerability assessment.

Vulnerability assessment:

Check for SQL Injection, XSS, and weak authentication. Examine session management and password policies. Test access controls and user permissions. Identify insecure configurations and input-validation problems.

Exploitation:

validate vulnerabilities using authorized test accounts. check whether normal users can access administrator functions. Test for improper privilege escalation. Real employee data must not be accessed or modified.

Defense - in - Depth:

use strong authentication and proper authorization. Deploy WAFs and firewalls for additional protection. use network segmentation and secure coding. continuously monitor suspicious activities.

Conclusion:

Penetration testing identifies weakness before exploitation. Authentication and access control protect employee information. multiple security layers reduce attack risks. Regular testing improves system security.

Q5. University Wi-Fi Dos Attack

Introduction:

The university experiences frequent Wi-Fi disruptions. Excessive or abnormal traffic may be causing the problem. A Dos attack or network misconfiguration may be responsible. A controlled security assessment is required.

Dos Attack:

Dos attempts to make a service unavailable. It can consume network or system resources. Legitimate users may experience slow or unavailable services.

Dos attacks use multiple systems to generate traffic

Identifying the cause:

Monitor normal and abnormal network traffic.

Investigate excessive packets and repeated requests.

Identify unknown or suspicious devices. Analyze unusual protocols and traffic patterns.

Kali Linux Tools:

Wireshark captures and analyzes network packets. tcpdump collects network traffic information. Nmap identifies hosts and network services. Kismet monitors wireless network.

Impact:

Dos attacks can make university Wi-Fi unavailable. Students may lose access to online learning resources. online examinations and university systems may be affected. Network disruption reduces productivity.

Counter measures:

Use firewalls to control unwanted traffic. Apply rate limiting to reduce excessive requests. Deploy IDS/IPS for detecting suspicious activities. Use network segmentation and continuous monitoring.

Conclusion:

DOS attacks can seriously affect network availability. traffic monitoring helps detect abnormal behaviour. Firewalls and IDS/IPS provide important protection. Regular monitoring improves university Wi-Fi security.